

CVEs más relevantes de la semana

Del 12/09/2026 al 19/09/2026

Porque el primer paso para defender es conocer las amenazas.



CVE-2026-18119

Descripción: Concrete CMS below 9.5.3 did not sanitize custom style values in the Block Design dialog before writing them into page CSS via a DOM sink, permitting stored cross-site scripting. An editor-level user could execute script in an administrator's session and escalate privileges. The Concrete CMS security team gave this vulnerability a CVSS v4.0 score of 7.0 with vector CVSS:4.0/AV:N/AC:L/AT:N/PR:H/...

CVSS: 9.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:C/C:H/I:H/A:H

Tipo: CWE-79

Tecnología: No especificado

Publicado el: 2026-09-14



CVE-2026-43790

Descripción: The issue was addressed with improved memory handling. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. A remote attacker may be able to cause unexpected system termination or corrupt kernel memory.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: CWE-787

Tecnología: No especificado

Publicado el: 2026-09-14



CVE-2026-65381

Descripción: A validation issue existed in the entitlement verification. This issue was addressed with improved validation of the process entitlement. This issue is fixed in macOS Golden Gate 27, macOS Sequoia 15.8, macOS Tahoe 26.7. A malicious app may be able to break out of its sandbox.

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-862

Tecnología: No especificado

Publicado el: 2026-09-14



CVE-2026-39919

Descripción: Ghostscript before 10.08.0 contains a heap-based buffer overflow vulnerability in the JPEG 2000 output adapter (base/sjpx_openjpeg.c) that allows attackers to cause memory corruption by supplying a crafted PDF containing a JPEG 2000 image with mismatched component subsampling factors. When image components declare different subsampling values, the non-samescale sub-byte-depth output path alloca...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-122

Tecnología: No especificado

Publicado el: 2026-09-15



CVE-2024-58385

Descripción: Yonyou U8 CRM contains an unauthenticated SQL injection vulnerability in the fillbacksettingedit.php configuration endpoint where the DontCheckLogin=1 parameter bypasses authentication and the id parameter is incorporated into SQL queries without sanitization. Attackers can exploit this flaw to execute arbitrary SQL commands and, on Microsoft SQL Server deployments with xp_cmdshell enabled, wri...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-09-15



CVE-2026-83149

Descripción: Vulnerability in Oracle Application Testing Suite. The supported version that is affected is 13.3.0.1. Easily exploitable vulnerability allows low privileged attacker having Test Manager for Web Apps privilege with network access via HTTP to compromise Oracle Application Testing Suite. While the vulnerability is in Oracle Application Testing Suite, attacks may significantly impact additional...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:L/A:L

Tipo: N/A

Tecnología: No especificado

Publicado el: 2026-09-15



CVE-2026-83197

Descripción: Vulnerability in the Siebel Apps - Financial Services product of Oracle Siebel CRM (component: Financial Accounts). Supported versions that are affected are 17.0-26.7. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Siebel Apps - Financial Services. Successful attacks of this vulnerability can result in unauthorized access to critic...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:H

Tipo: N/A

Tecnología: No especificado

Publicado el: 2026-09-15



CVE-2026-92717

Descripción: Covenant through 0.6 registers the CovenantHub SignalR hub without an Authorize attribute, allowing unauthenticated callers to invoke CreateHttpListener and receive a signed JWT token. Attackers can use the obtained token to authenticate against the entire operator API and access grunts, credentials, binaries, events, and the operator roster.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-09-16



CVE-2026-93603

Descripción: vm2 through 3.12.0 (fixed in 3.12.1) does not correctly handle a nullish `this` receiver in the apply trap of its bridge (lib/bridge.js): when sandboxed code calls a host-provided non-strict (sloppy-mode) function without a receiver — e.g. `fn()`, a detached method, `fn.call()`, `fn.apply(undefined)`, `Reflect.apply(fn, undefined, [])`, or `fn.bind>()` — the undefined receiver is passed straig...

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-09-18



CVE-2026-93605

Descripción: vm2 NodeVM versions before 3.12.1 contain a sandbox escape vulnerability where the DANGEROUS_BUILTINS denylist omits child_process despite blocking other host-spawning modules.

Attackers can require child_process and execute arbitrary commands on the host system when NodeVM is configured with builtin:['*'] or explicit child_process allowance.

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-693

Tecnología: No especificado

Publicado el: 2026-09-18



CVE-2023-54399

Descripción: Hongjing e-HR before 8.2 contains a SQL injection vulnerability in the /servlet/codesettree endpoint where the categories query parameter is passed to a database query without sanitization after HRMS-encoding is stripped. An unauthenticated remote attacker can supply a crafted UNION SELECT payload to read arbitrary database content, including credential tables such as operuser. Exploitation evi...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-09-18



CVE-2026-75878

Descripción: IBM Sterling File Gateway could allow a remote attacker to bypass authentication and obtain a fully authenticated session due to improper authentication via an unvalidated SSO header.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-09-18



CVE-2026-80441

Descripción: IBM Guardium Data Protection 12.2 is vulnerable to an unauthenticated second-order SQL injection vulnerability in the generateInsertQuery functionality of change-tracker-data.sql. A remote attacker could inject malicious SQL that is subsequently processed by the application, potentially resulting in compromise of the confidentiality, integrity, and availability of the affected system.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-09-18



CVE-2026-80442

Descripción: IBM Guardium Data Protection 12.2 is vulnerable to an authenticated OS command injection vulnerability in the exportCertificate functionality. Successful exploitation could allow an attacker to execute unauthorized commands and impact the confidentiality, integrity, and availability of the affected system.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-09-18



CVE-2026-81657

Descripción: IBM Guardium Data Protection 12.2 could allow a remote unauthenticated attacker to execute arbitrary code on the system due to the deserialization of untrusted data.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-502

Tecnología: No especificado

Publicado el: 2026-09-18



CVE-2026-82340

Descripción: IBM Guardium Data Protection 12.2 is vulnerable to unauthenticated insecure deserialization and attacker-controlled reflective method dispatch in the Change Audit System (CAS) listener. A network attacker able to reach TCP port 16017 may submit crafted serialized messages and potentially cause unintended code execution in the Guardium appliance.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-09-18



CVE-2026-82832

Descripción: IBM Guardium Data Protection 12.2 could allow a remote authenticated attacker to execute arbitrary code due to improper neutralization of input during web page generation.

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:N

Tipo: CWE-79

Tecnología: No especificado

Publicado el: 2026-09-18



CVE-2026-82967

Descripción: IBM Guardium Data Protection 12.2 is vulnerable to an authentication bypass that allows an unauthenticated remote attacker to bypass IP-based access controls and access the Guardium management interface.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-09-18



CVE-2026-84064

Descripción: IBM Guardium Data Protection 12.2 could allow a remote authenticated attacker to execute arbitrary SQL commands due to improper neutralization of special elements used in an SQL command.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-09-18



CVE-2026-84073

Descripción: IBM Guardium Data Protection 12.2 could allow a remote authenticated attacker to execute arbitrary SQL commands due to improper neutralization of special elements used in an SQL command.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:L/A:L

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-09-18



CVE-2026-84075

Descripción: IBM Guardium Data Protection 12.2 could allow a remote attacker to bypass security restrictions due to missing authentication for the ChangeTrackerServlet.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:L/I:H/A:L

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-09-18



CVE-2026-84078

Descripción: IBM Guardium Data Protection 12.2 is vulnerable to a missing authentication vulnerability in the LoadBalancerServlet. An unauthenticated user can access privileged load-balancer operations, potentially resulting in unauthorized actions and impact to the integrity and availability of the affected system.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:L/I:H/A:L

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-09-18



CVE-2026-84082

Descripción: IBM Guardium Data Protection 12.2 could allow a remote attacker to execute arbitrary SQL commands due to improper neutralization of special elements used in an SQL command.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-09-18



CVE-2026-93839

Descripción: LightLLM through 1.2.0 contains an authentication bypass vulnerability in the /pd_register WebSocket endpoint that allows unauthenticated attackers to register arbitrary nodes by supplying crafted JSON without peer address validation. Attackers can disclose full user prompts routed to their socket, trigger denial of service by replacing legitimate nodes, or make the PD Master issue requests to ...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-09-18



CVE-2026-93738

Descripción: A vulnerability was found in Totolink A3002MU Hh-B20211125.1046. This affects the function formSchedule of the file /boafrm/formSchedule. Performing a manipulation of the argument webpage results in buffer overflow. The attack is possible to be carried out remotely. The exploit has been made public and could be used.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-119

Tecnología: No especificado

Publicado el: 2026-09-18



CVE-2026-75885

Descripción: A flaw was found in the OpenShift console. Unauthenticated access to the `/api/devfile/` and `/api/devfile/samples/` endpoints allows a remote attacker to send crafted devfile payloads. This can lead to Server-Side Request Forgery (SSRF), where the console pod makes requests to internal services and reflects partial responses to the attacker. Additionally, by sending repeated large requests wit...

CVSS: 9.3 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:N/A:L

Tipo: CWE-918

Tecnología: No especificado

Publicado el: 2026-09-18



CVE-2026-93739

Descripción: A vulnerability was determined in Totolink A3002MU Hh-B20211125.1046. This impacts the function formWlAc of the file /boafrm/formWlAc. Executing a manipulation of the argument submit-url can lead to buffer overflow. The attack may be performed from remote. The exploit has been publicly disclosed and may be utilized.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-119

Tecnología: No especificado

Publicado el: 2026-09-18



CVE-2026-93740

Descripción: A vulnerability was identified in Totolink A3002MU Hh-B20211125.1046. Affected is the function formWlEncrypt of the file /boafrm/formWlEncrypt. The manipulation of the argument submit-url leads to buffer overflow. It is possible to initiate the attack remotely. The exploit is publicly available and might be used.

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-119

Tecnología: No especificado

Publicado el: 2026-09-18



CVE-2026-93741

Descripción: A security flaw has been discovered in Totolink A3002MU Hh-B2021125.1046. Affected by this vulnerability is the function formWlWds of the file /boafrm/formWlWds. The manipulation of the argument submit-url results in buffer overflow. It is possible to launch the attack remotely. The exploit has been released to the public and may be used for attacks.

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-119

Tecnología: No especificado

Publicado el: 2026-09-19



CVE-2026-93742

Descripción: A weakness has been identified in Totolink A3002MU Hh-B20211125.1046. Affected by this issue is the function formWsc of the file /boafrm/formWsc. This manipulation of the argument localPin causes command injection. The attack can be initiated remotely. The exploit has been made available to the public and could be used for attacks.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-74

Tecnología: No especificado

Publicado el: 2026-09-19



CVE-2026-93985

Descripción: OpenPanel js-runtime through commit bad75bdd contains a sandbox escape vulnerability in the JavaScript webhook template validator that fails to block computed member access to constructor chains. Attackers with project write access can create webhook templates using computed property notation to access Function constructor and execute arbitrary code in the worker process.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-09-19



Resumen del Reporte

CVEs analizados: 31

Promedio CVSS: 9.67

Fuente: nvd.nist.gov

Nos vemos la próxima semana. Hack the Cat ☹

